

Privilege Escalation & Lateral Movement

Why This Matters

Most initial access lands as a `low-privilege user`. The attack isn't over – the attacker now wants:

`Vertical escalation (PrivEsc)` – user → root/administrator/SYSTEM on this box

`Lateral movement` – this box → other boxes

`Persistence` – survive reboots

`Goal` – the crown jewels (domain admin, data, identity)

Vertical PrivEsc Patterns

Misconfigurations:

World-writable / SUID binaries (Linux: `find / -perm -4000`)

Sudo misconfig (`sudo -l` – check what you can run as root)

Unquoted service paths (Windows)

Weak service permissions (Windows services startable by users)

Kernel bugs:

Known CVE + public exploit (Dirty COW, etc.)

Unpatched = free root

Credential reuse:

Same password user→admin

Credentials in config files, registry, memory

Abuse of functionality:

`docker run --privileged` via a user in the docker group → root

Web shells running as the web-server user

Lateral Movement Patterns

Pass-the-Hash/NTLM reuse – use the hash, no password needed

RDP/SSH hopping – legit remoting abused

Psexec/SMB exec – remote services

WMI / WinRM – Windows-native remote execution

GPO/Scheduled Tasks across the domain

Detecting Movement (Blue Team)

Signal	Where
New remote admin session (4624 LogonType 3/10)	Windows security log
Services created on endpoints (7045)	Windows
SMB admin tunnels (TreeConnect to ADMIN\$)	network / EDR
Unexpected RDP/WinRM	firewall / EDR
New admin users on hosts	events 4720/4728

Analyst habit: whenever you see nonsense logins from ONE source to MANY hosts in a short window – that's lateral movement or a scan. Both are worth investigating.

The Bootstrapped Privileged Session

CISOs love this: even a stolen low-priv session lets an attacker:

Read the file where creds sit

Kerberoast / mine a ticket

Spray those creds across dozens of hosts until one works

Reach a service account → domain admin

Because an attacker only needs ONE misconfigured credential to escalate, defense = (a) eliminate exploitable configs, (b) detect any escalation.

[← RBAC, ABAC & Authorization M...](#)

Module complete ✓